

REDES Y SEGURIDAD 2

PRÁCTICA 1.1



JOHNNY: Bueno, bueno... así que esto es la Facultad de Informática... pero tú no has venido a rellenar formularios. Hoy vas a aprender cómo se engaña a las máquinas para que te hablen como si fueras el jefe o la jefa. ARP spoofing. Man in the Middle... suena sucio... y lo es. Pero entender esto es entender cómo se

doblega la red a tu voluntad. Vamos, que hoy no vienes a hacer prácticas... vienes a jugar con fuego.

En esta práctica aprenderás a:

- Usar la máquina virtual de la asignatura.
- Realizar un ataque "man-in-the-middle" usando el protocolo ARP.



El usuario y la contraseña de la máquina virtual son **silverhand** y **samurai**, respectivamente.

Para realizar las prácticas dispones de una máquina virtual llamada **RS2-Relic**, que se lanza usando **VirtualBox**. Dentro, los diferentes escenarios (chambas) se despliegan usando la tecnología **docker**.

Para poder usar esta máquina virtual deberás copiarla del directorio de la asignatura: **/mnt/DiscoVMs/RS2** a tu *HOME* de usuario.

Una vez que TODO el directorio se ha copiado, podrás hacer doble click sobre el archivo **.vbox**. Una vez arrancada la máquina virtual, te encontrarás con 3 iconos en el escritorio:

- **Terminal**: acceso a la terminal.
- **Firefox**: navegador web.
- **Remmina**: acceso a escritorio remoto mediante RDP.

Los escenarios se gestionan desde la terminal, usando un script llamado *chamba*. Este script permite listar los escenarios disponibles y lanzarlos.

```
> ./chamba -l #listar escenario
```

```
> ./chamba -i ESCENARIO #lanzar escenario
```

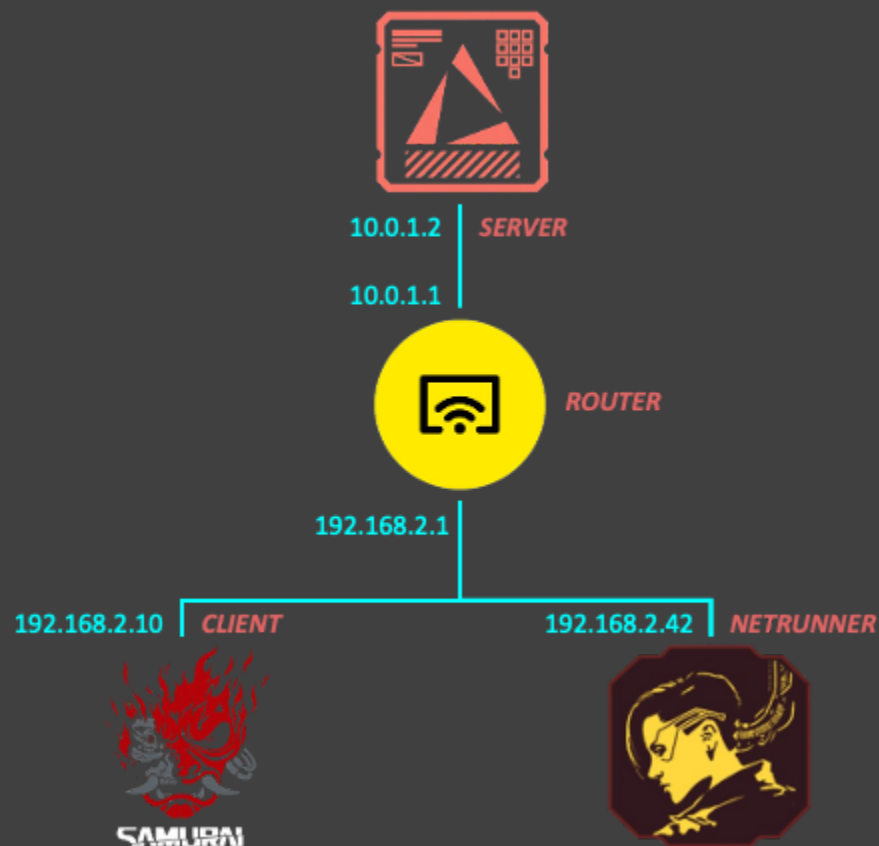
Una vez lanzado el escenario, las máquinas (realmente contenedores) serán accesibles por terminal. Para ello se usará el script *chipper*.

```
> ./chipper -l #listar máquinas
```

```
> ./chipper -c MÁQUINA #conectarse a máquina
```

Existe una máquina (contenedor), que cuenta con entorno gráfico (**client**). A ésta se puede acceder utilizando **Remmina**.

CHAMBA: P11-MitM



Las máquinas **client** y **netrunner** deberán añadir con **ip route** una ruta a la red 10.0.1.0/24, indicando la IP del **router** que está en su propia red.

Por su parte, **server** hará lo mismo, pero con la red 192.168.2.0/24.

PUNTO DE PARTIDA

SERVER

Se desplegará un servidor IRC (Internet Relay Chat).

1. Editar el fichero **/etc/ngircd/ngircd.conf**.
2. Descomentar la línea que contiene **Password** y darle un valor.
3. Lanzar el servidor usando el comando **service**.

NETRUNNER

Para interceptar el tráfico de la red, se usará la versión de **wireshark** para terminal.

> **tshark**

CLIENT

Hacer **ping** a la IP de **server** y cortarlo después de un rato.



¿Consigue captarse desde **netrunner** todo el tráfico?

CLIENT (usando Remmina)

Conectar al escritorio remoto de **client** usando **Remmina** en la máquina virtual **RS2-Relic**. La configuración del mismo ya está introducida en la aplicación.

Se deberá ignorar el aviso relativo al certificado digital.

Abrir la aplicación **HexChat** (buscarla en el menú de Aplicaciones).

1. Elegir un apodo y nombre de usuario (*idea: V*).

CLIENT (usando Remmina)

2. Crear una nueva red.
3. El servidor es la IP de **server** y el puerto, **6667**.
4. Desmarcar la opción de "Usar SSL en todos los servidores de esta red".
5. Introducir la contraseña indicada en el fichero de configuración del servidor en **server**.

Cuando esté todo, pinchar en conectar.

Una vez se realice la conexión, se preguntará qué se quiere hacer a continuación. Se indicará "Nada, me uniré a un canal después".

A continuación, unirse a un canal (se creará automáticamente si no existiera previamente).

> /join #CANAL

(idea: AfterLife)

Escribir algún mensaje en el canal y salir de **HexChat**.



¿Consigue captarse desde **netrunner** todo el tráfico?

ATAQUE MAN IN THE MIDDLE

Para realizar este ataque son necesarias 2 acciones simultáneas:

1. Engañar a **client** para hacerle creer que **netrunner** es **router**.
2. Hacer que **netrunner** actúe como si fuera **router**.



Puedes abrir tantas terminales como quieras en cualquier máquina (no sólo **netrunner**) usando el script **./chipper**.

NETRUNNER

Ejecutar el comando **fragrouter**, indicando que se quiere realizar forwarding IP normal.

NETRUNNER

A la vez, ejecutar el comando **arpspoof**, indicando que el objetivo es **client** y el host al que suplantar es **router**.

Seguir capturando el tráfico con **tshark**.



¿A qué protocolo pertenecen los mensajes generados y en qué consisten?

CLIENT

Hacer **ping** a la IP de **server** y cortarlo después de un rato.



Para cortar el **ping** o terminar la ejecución de cualquier programa en la terminal debes usar **CTRL+C**.



¿A qué protocolo pertenecen los nuevos mensajes y en qué consisten?

EXPLORAR LAS POSIBILIDADES DE TSHARK

NETRUNNER

Parar la captura con **tshark**.

Volver a lanzar **tshark** indicando que sólo se quiere capturar el tráfico del protocolo icmp con la opción **-f PROTOCOLO**.

CLIENT

Hacer **ping** a la IP de **server** y cortarlo después de un rato.

NETRUNNER

Parar la captura con **tshark**.

Volver a lanzar **tshark** indicando ahora que se quiere capturar el protocolo arp y la opción **-v**.

CLIENT

Hacer **ping** a la IP de **server** y cortarlo después de un rato.

NETRUNNER

Parar la captura con **tshark**.

CULMINAR EL ATAQUE

NETRUNNER

Se va realizar la captura con **tshark**, volcando el resultado en un archivo.

Para ello se indicará lo siguiente:

- Con la opción **-f** se indicará "**tcp port 6667**" (con comillas).
- El fichero en el que se volcará la captura se llamará **irc.cap** y para ello se usará la opción **-w**.
- El formato de salida será **fields**, utilizando la opción **-T**
- Se usará la opción **-e** para pedir que se quieren volcar los datos (**data**).

CLIENT (usando Remmina)

Volver a conectarse al servidor IRC en **server**.

Realizar las mismas acciones que en la anterior sesión (unirse a un canal y escribir algo en el mismo).

Salir del servidor IRC.

NETRUNNER

Parar la captura con **tshark**.

Procesar el fichero de captura ejecutando nuevamente **tshark** pero indicando:

- El fichero en cuestión, usando la opción adecuada.
- Que se seguirá el flujo de datos (**follow,tcp,ascii,0**) con la opción **-z**.
- El mínimo nivel de salida (**-q**), para centrarnos exclusivamente en el flujo de datos.

NETRUNNER

Una vez ejecutado, extraer del flujo de datos la contraseña utilizada para conectarse a **server**, así como las acciones realizadas por **client**.



¿En qué sentido de la comunicación se está afectado con este ataque? ¿Por qué?

¿Por qué la repetición constante de mensajes generados por arpspoof?

Si no se hubiera especificado un objetivo, **arpspoof** mandaría mensajes a todas las máquinas de la red. ¿Es esto recomendable?

¿Por qué se realiza el forwarding?

_ EOL



"Donde las dan, las toman". Realiza el mismo ataque pero invirtiendo el objetivo y la máquina suplantada. Esto te podría ser útil más adelante.